Network Fundamentals and Security in IT Infrastructure Services

By,

Mr. Kumar Pudashine, (MEng, AIT, Bangkok)
PMP, CISA, CISM, CRISC, CNDA, CDCP, COBIT 5, CCNP (Enterprise), JNCIA, CEH v9, ITIL, ISO 27001:2022, AcitivIdentity Certified
Founder and President, Global Cybersecurity Community Forum
IEEE, ISACA, PMI Member

May 2025

Protocols : What It is ?

- A Protocol is a set of rules that governs Data Communications.
- For Communication to occur, the entities must agree on a Protocol.
- The Key Elements of a Protocol are
  - Syntax => Refers to Structure or Format of Data.
  - Semantics => Refers to Meaning of Each Data.
  - Timing => When Data Should be Sent and How Fast ?

"French Scientist Cannot Communicate With Japanese Scientist Without Any Protocol"

Standards : What It is ?

- Creates Open and Competitive Market for Manufacturers.
- Provides guidelines to Manufactures for Interoperability.
- Data Communication Standards Fall into Two Categories
  - *De facto*
  - *De jure*
- *De facto* Standards have not been approved by an Organization.
- Standards through Wide Spread Use are *De facto* Standards.
- *De jure* Standards have been legalized by an Organization.

Standard Organization

- International Organization for Standardization (ISO)
- International Telecommunication Union (ITU)
- American National Standards Institute (ANSI)
- Institute of Electrical and Electronics Engineers (IEEE)
- Electronic Industries Association (EIA)

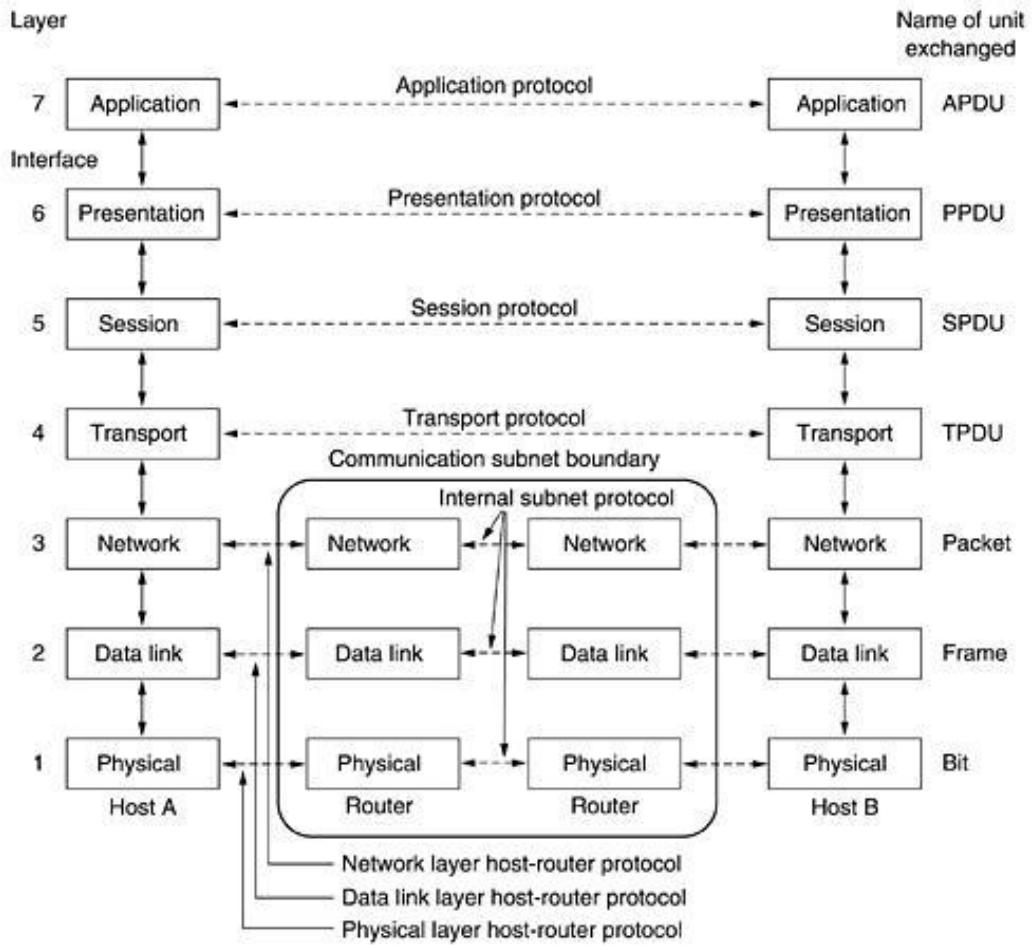
OSI Model

- Open System Interconnection
- Developed by International Organization for Standardization.
- It Consists of Seven Layers.
- Considered as a Reference Model.
- A Theoretical System Delivered Too Late.

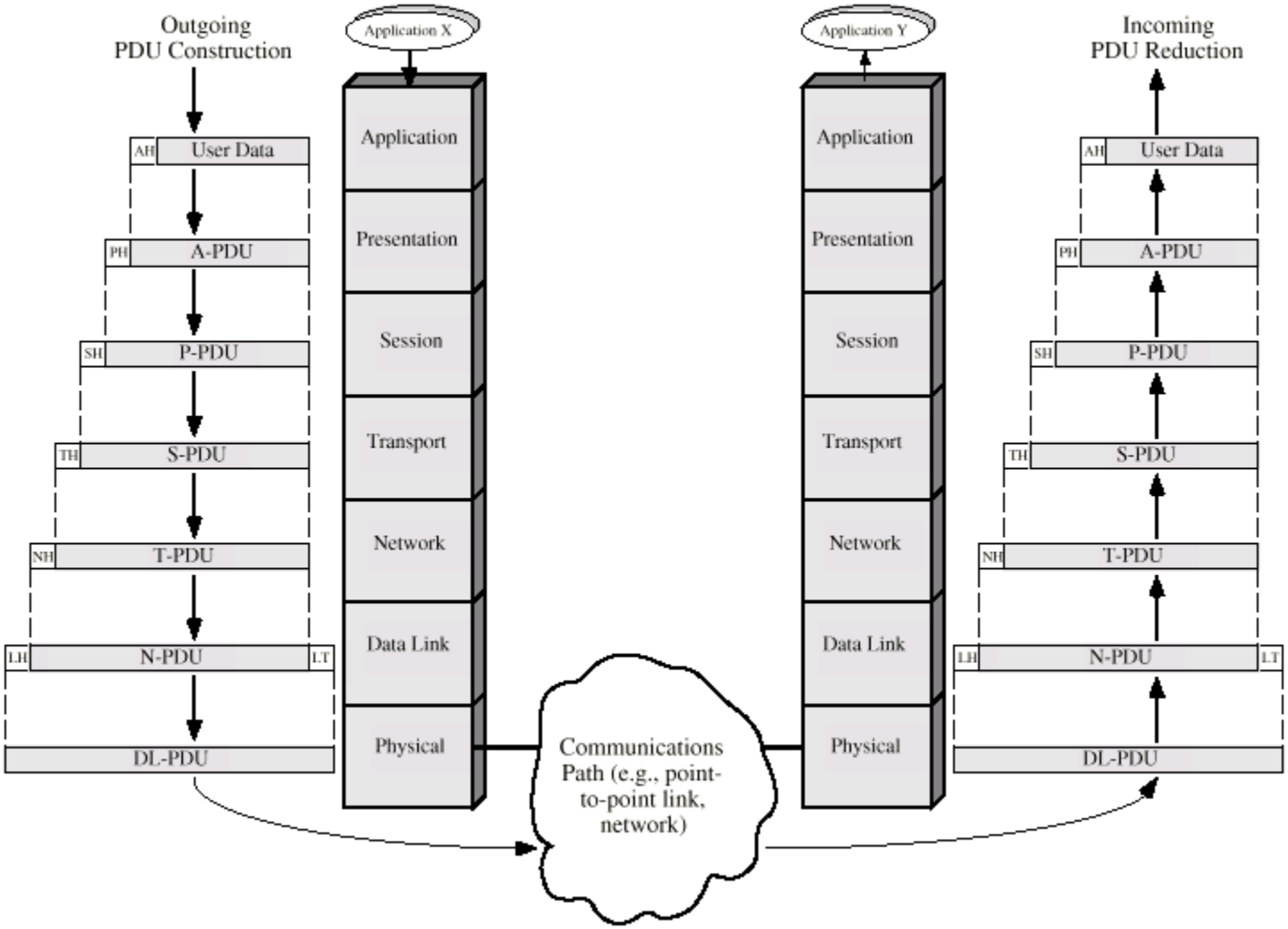
Why Layering ??

- To Separate Specific Functions in Each Layer.
- Each Layer Should Define a Unique Function.
- To make their Implementation Transparent to Other Components.
- Allows Independent Design and Testing of Each Components.
- Modularization Eases Maintenance and Updating of System.

The OSI Reference Model



The OSI Environment



OSI Layers : Functions

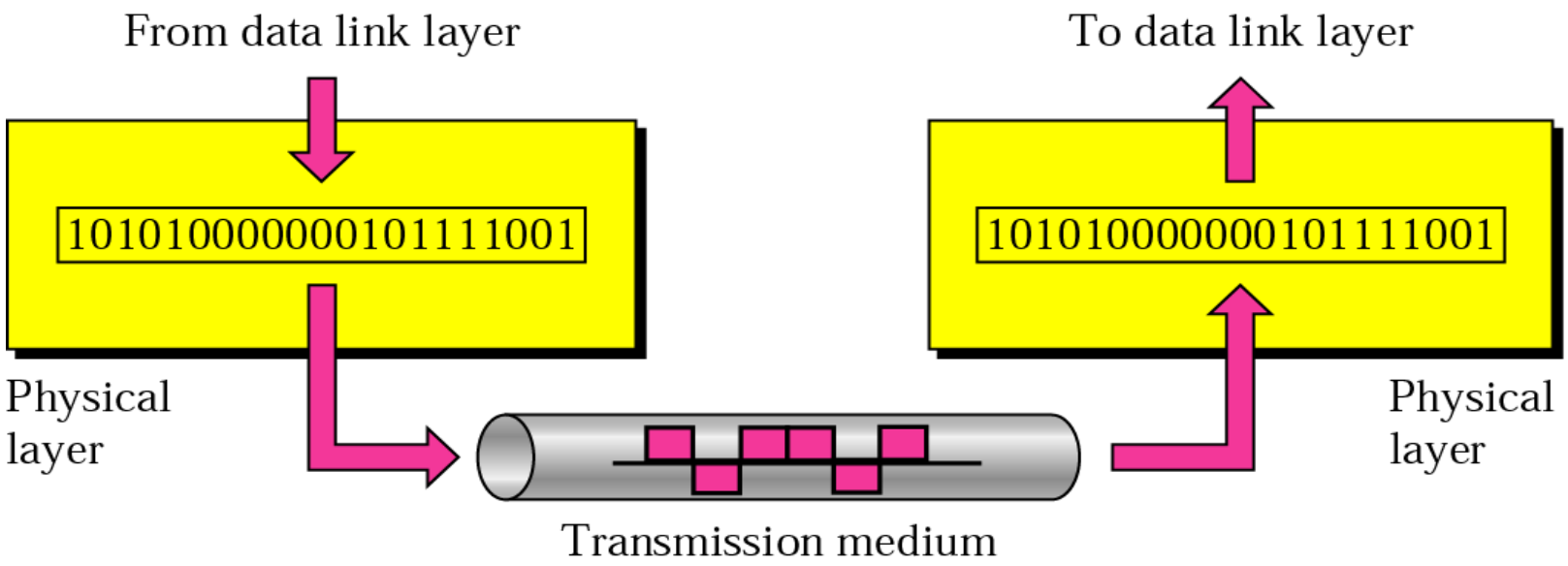
Physical Layer

- Responsible for Transmitting Individual Bits.
- Deals with Physical Characteristics of Interfaces and Medias. [Electrical and Mechanical]

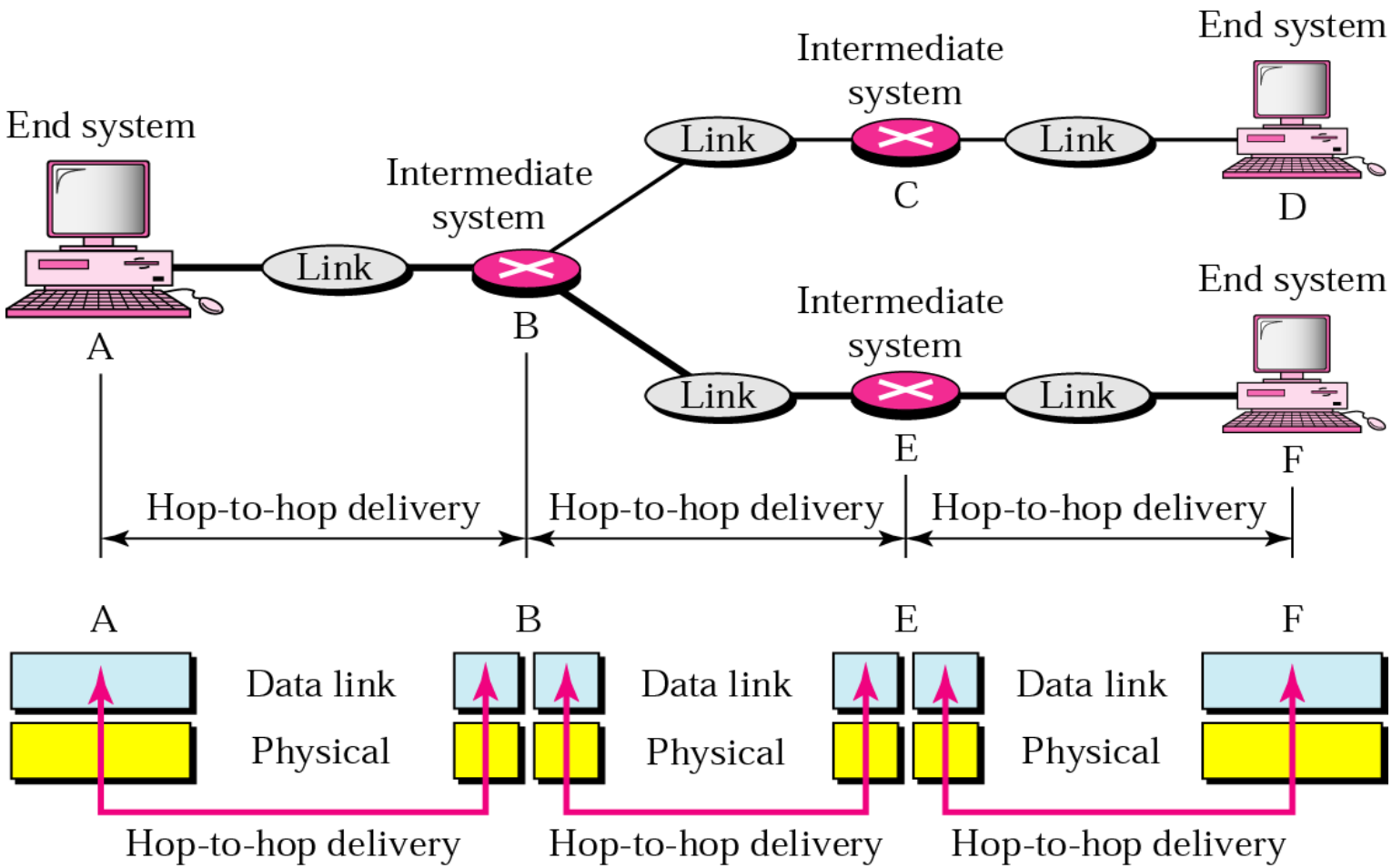
Data Link Layer

- Enables Node to Node Communication.
- Responsible for Transmitting Frames From One Node to Next.
- Framing
- Physical Addressing
- Error Control
- Access Control [E.g CSMA/CD]

OSI Layers : Physical Layer



Data Link Layer : Node to Node Delivery



OSI Layers : Functions

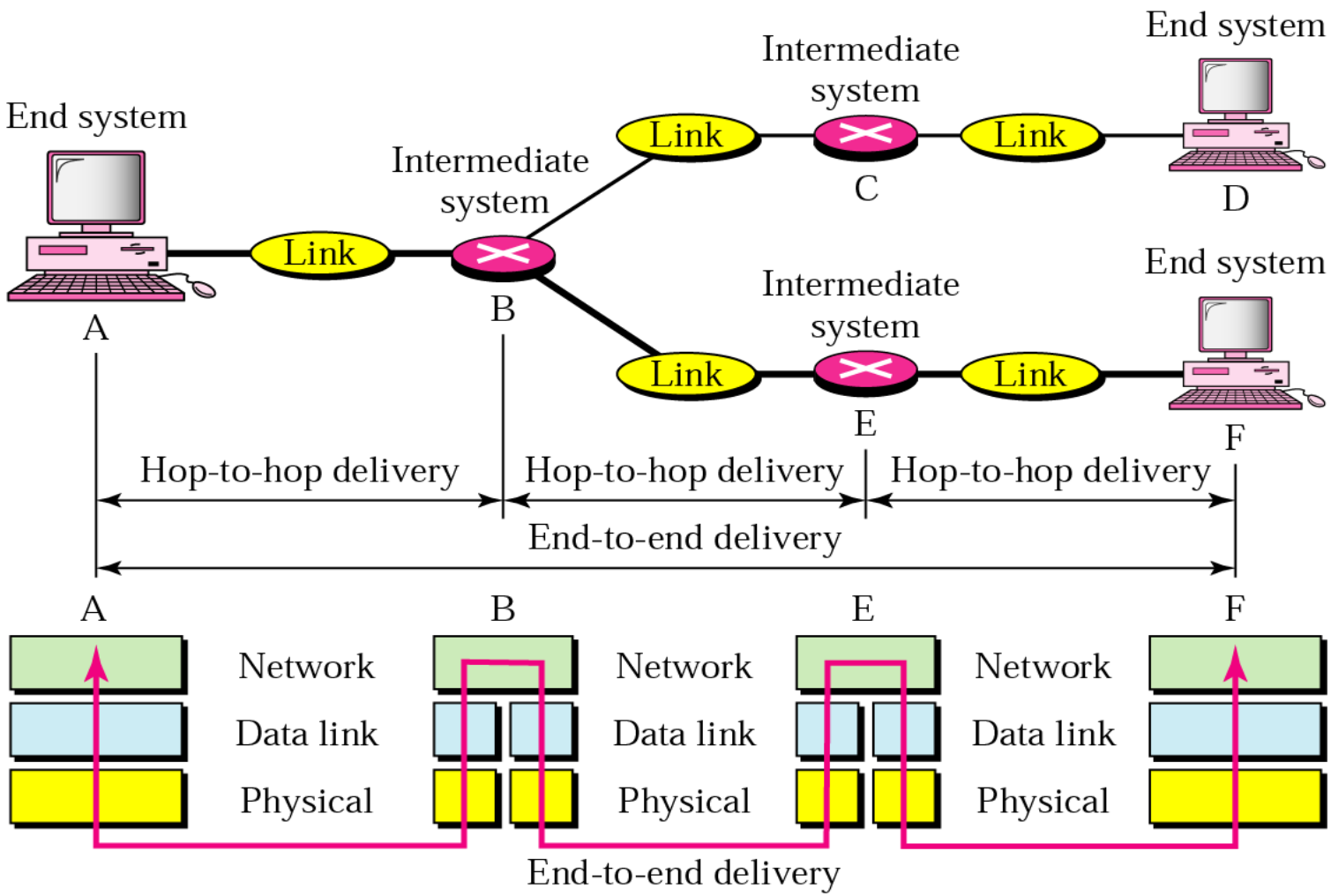
Network Layer

- Enables Host to Host Communication
- Responsible for Delivery of Packets
- Logical Addressing
- Routing

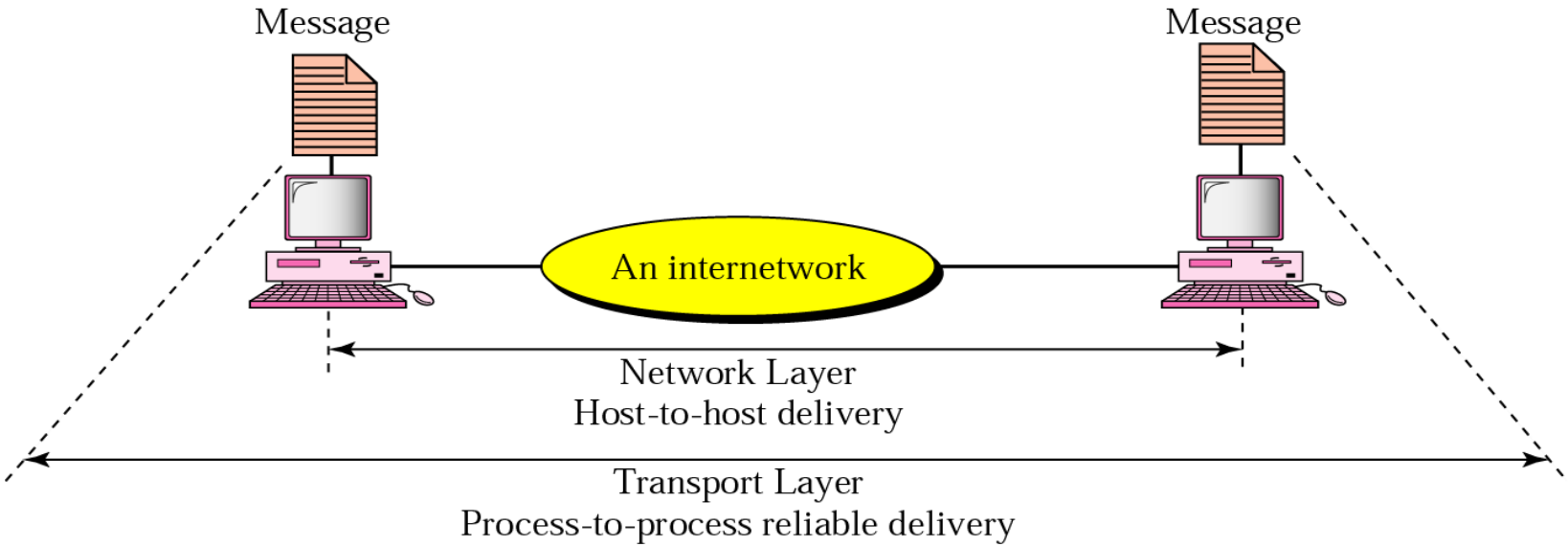
Transport Layer

- Enables Process to Process Communication.
- Port Addressing
- Segmentation and Reassembly.
- Connection Control
- Flow Control
- Error Control

Network Layer : End to End Delivery



Transport Layer : Process to Process Delivery



OSI Layers : Functions

Session Layer

- Control of Dialogues Between Applications.
- Whose Turn is To Transmit ??
- Dialogue Discipline => Half Duplex/ Full Duplex

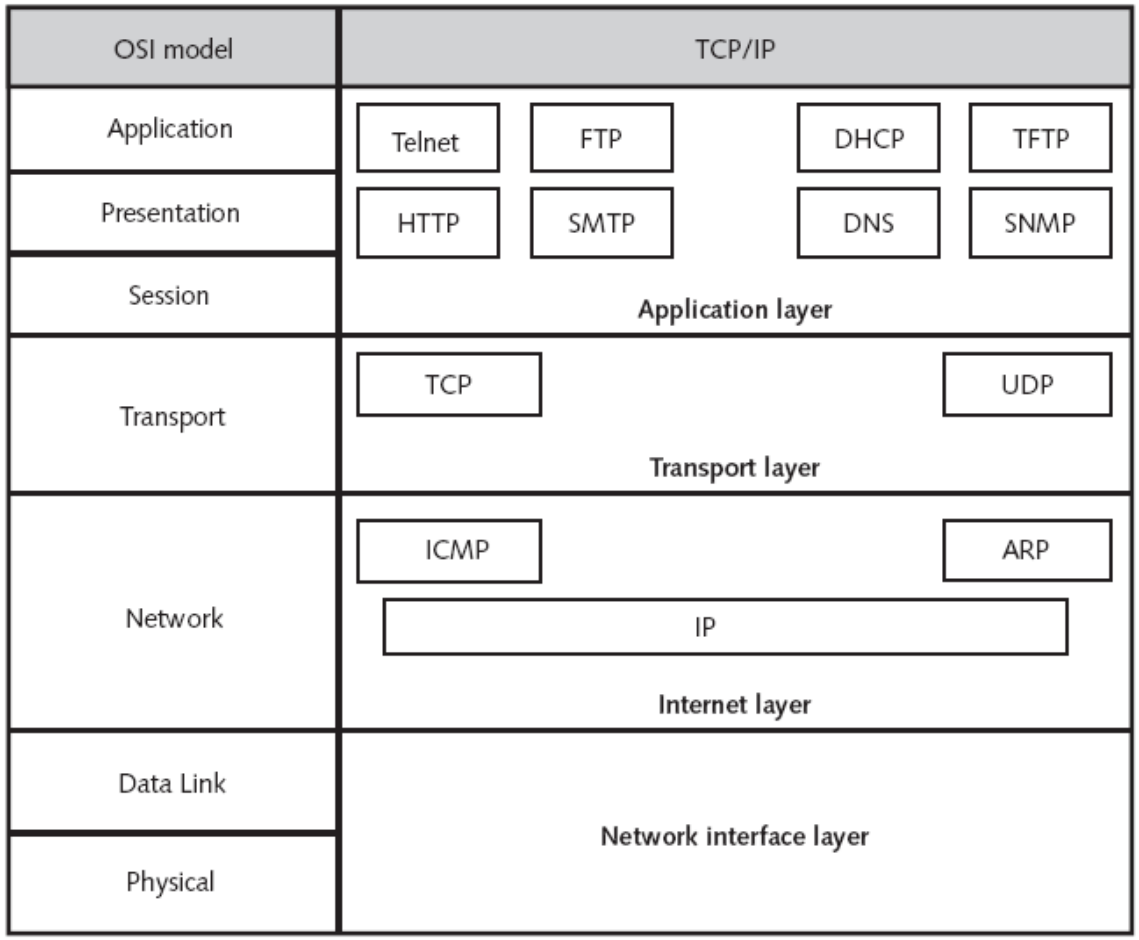
Presentation Layer

- Data Formats and Coding.
- Data Compression
- Encryption

Application Layer

- Responsible for Providing Service to End Users.
- Mail Transfer Service.
- File Transfer Service.

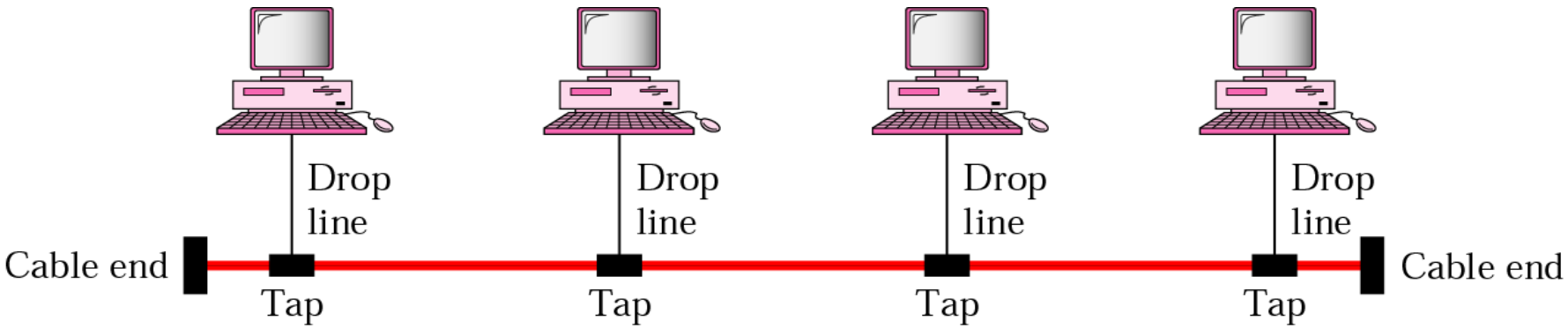
OSI Model Compared to TCP/IP



Physical Topologies : What It is ?

- Physical Layout of the Network.
- It is the geometric representation of the relationships of all the links and linking devices.
- Linking devices are called Nodes.
- Four Basic Possible Topologies are
  - Bus Topology
  - Star Topology
  - Mesh Topology
  - Ring Topology

Physical Topologies : Bus Topology



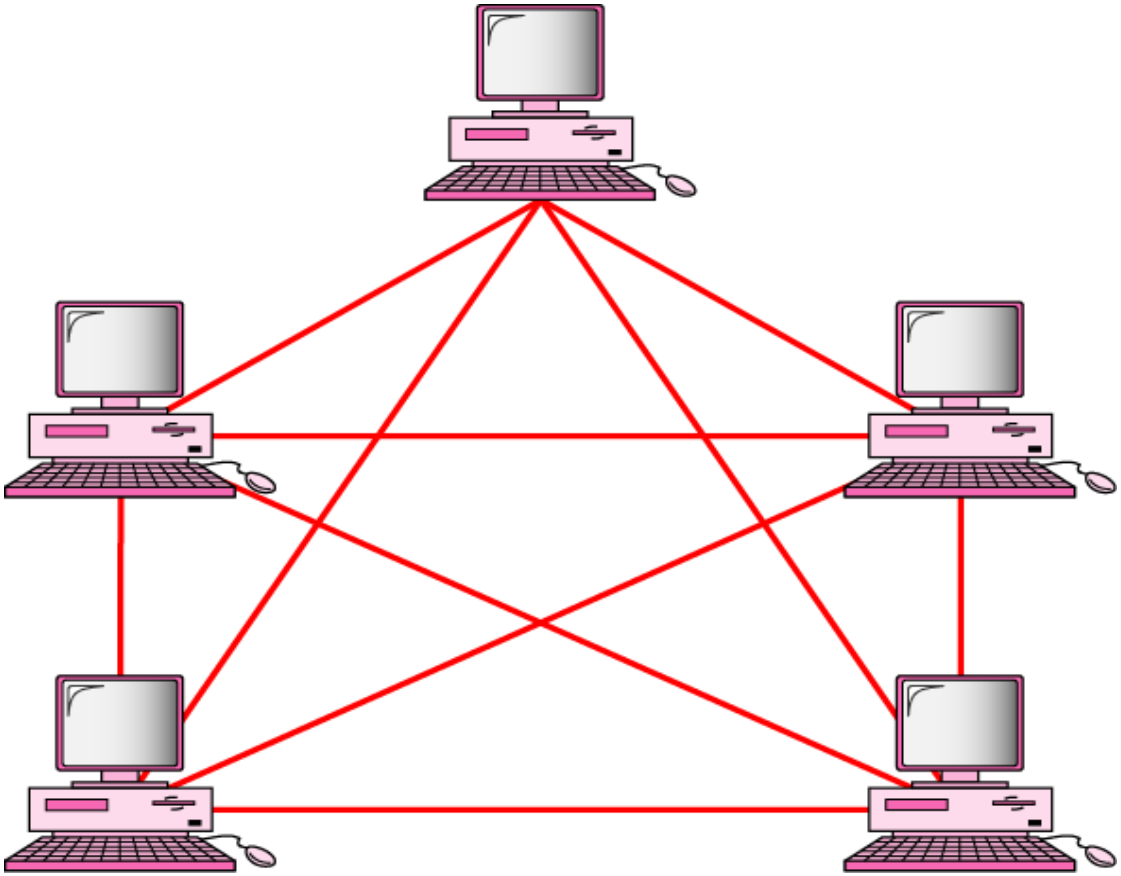
Physical Topologies : Bus Topology

- Bus Topology is Multipoint.
- One long cable acts as a backbone to link all the devices.
- Nodes are connected to the bus cable by drop line and taps.
- Taps = > T-Connector
- Terminators required for both ends of backbone cable.

- **Advantages**
  - Ease of Installation.
  - Requires less cabling.

- **Disadvantages**
  - Difficult reconnection and fault isolation.
  - Fault or break in bus cable stops all transmission.

Physical Topologies : Mesh Topology



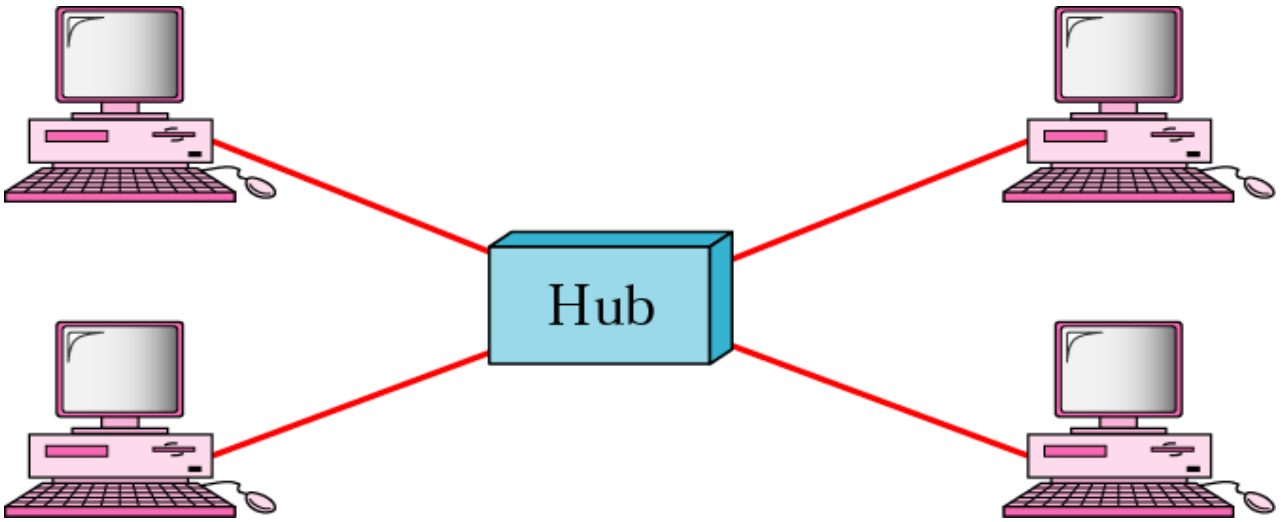
Physical Topologies : Mesh Topology

- Every device has a dedicated point to point link to other device.
- Fully connected Mesh Network has n(n-1)/2 links.
- Every device on the network must have n-1 I/O Ports.

- **Advantages**
  - Robust
  - Privacy and Security.
  - Fully Point to Point link makes Fault Isolation Easy.

- **Disadvantages**
  - More No of I/O Ports Required.
  - Amount of Cabling Required is more.
  - Cost High.

Physical Topologies : Star Topology



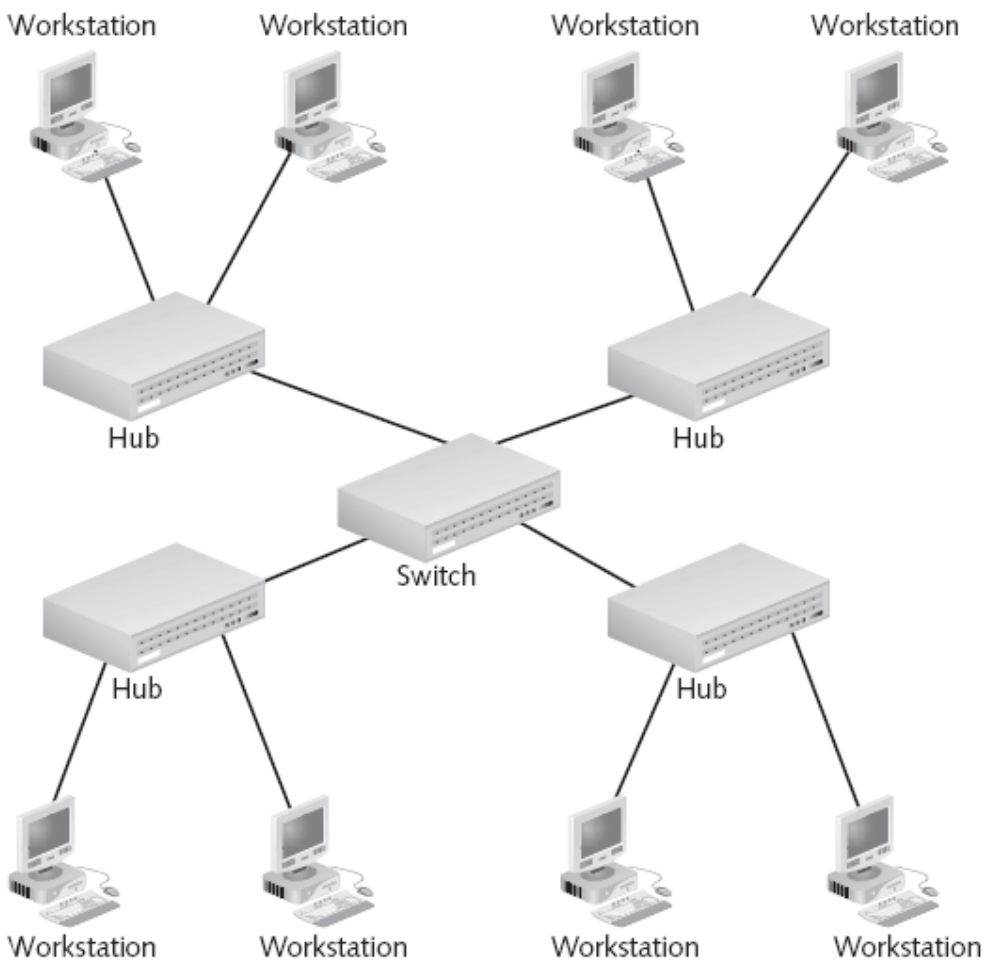
Physical Topologies : Star Topology

- Each device has a dedicated point to point link only to central controller.
- Central Controller => Hub or Switch
- Device are not directly linked to one another.
- Controller acts as an Exchange.
- Each device needs only one I/O Port.

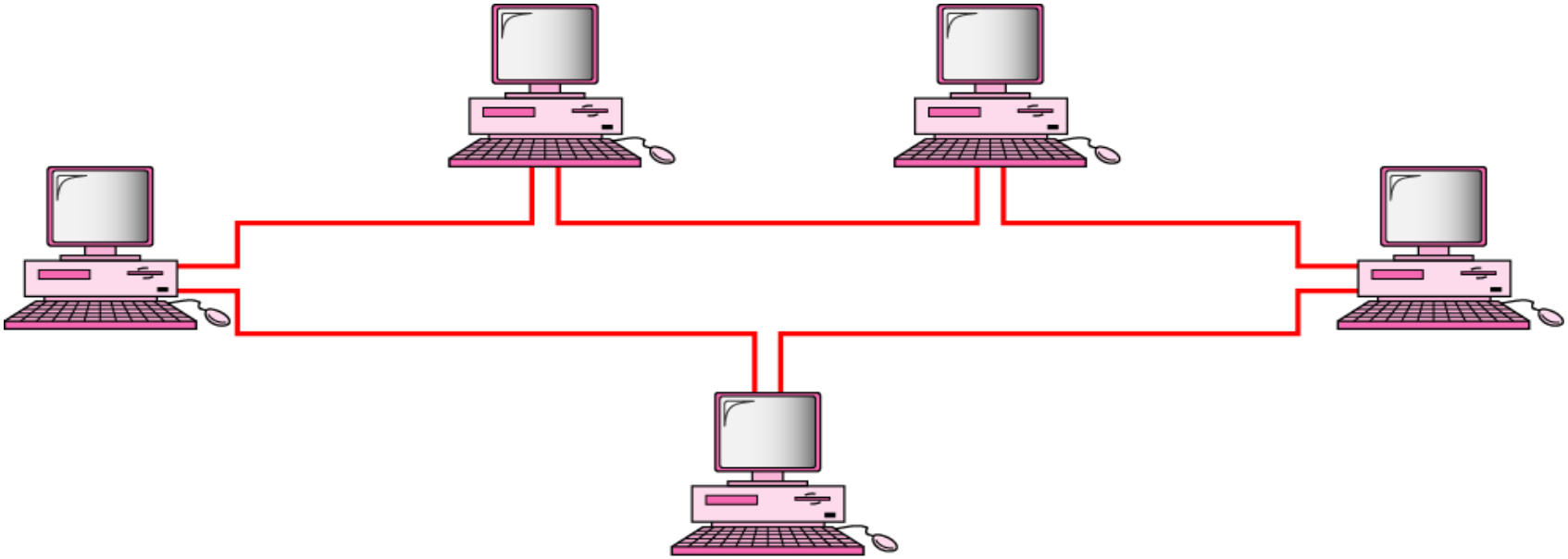
- **Advantages**
  - Easy to Install and Reconfigure.
  - Less Expensive than Mesh Topology.
  - Robustness
  - Easy for Fault Identification.

- **Disadvantages**
  - More Cabling required than Ring or Bus.

Physical Topologies : Extended Star Topology



Physical Topologies : Ring Topology



Physical Topologies : Ring Topology

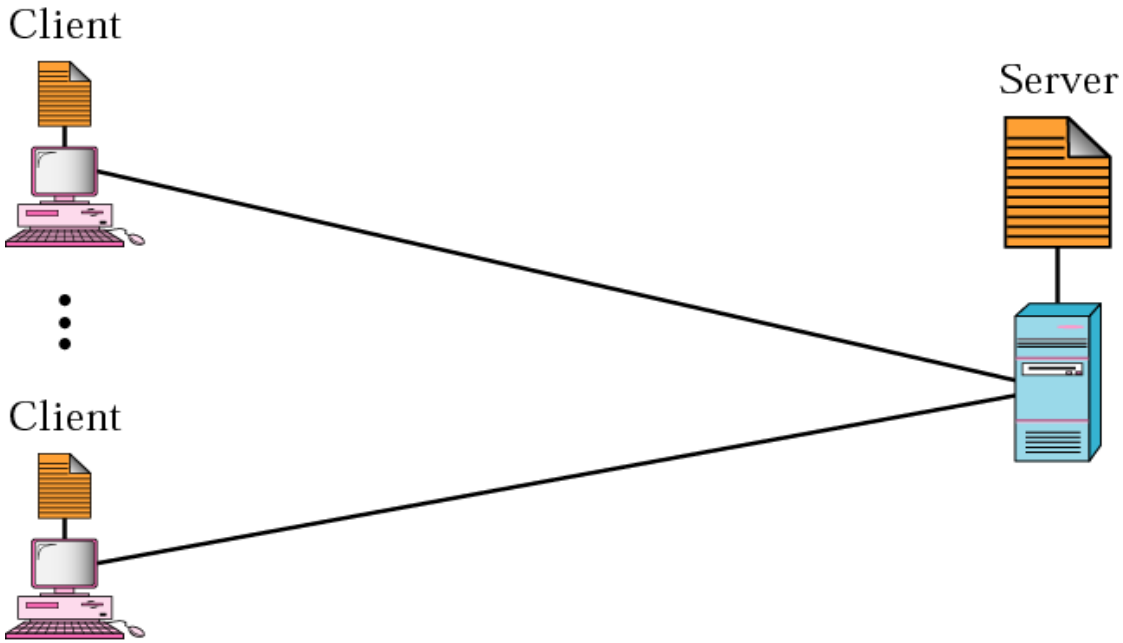
- Each device has a dedicated point to point connection only with two devices.
- A signal is passed along with the ring in one direction from device to device.
- Each device in the ring incorporates a repeater.
- **Advantages**
  - Easy to Install and Reconfigure.
- **Disadvantages**
  - Unidirectional Traffic.
  - A Break in Ring can disable the entire Network.

Network Models: Types

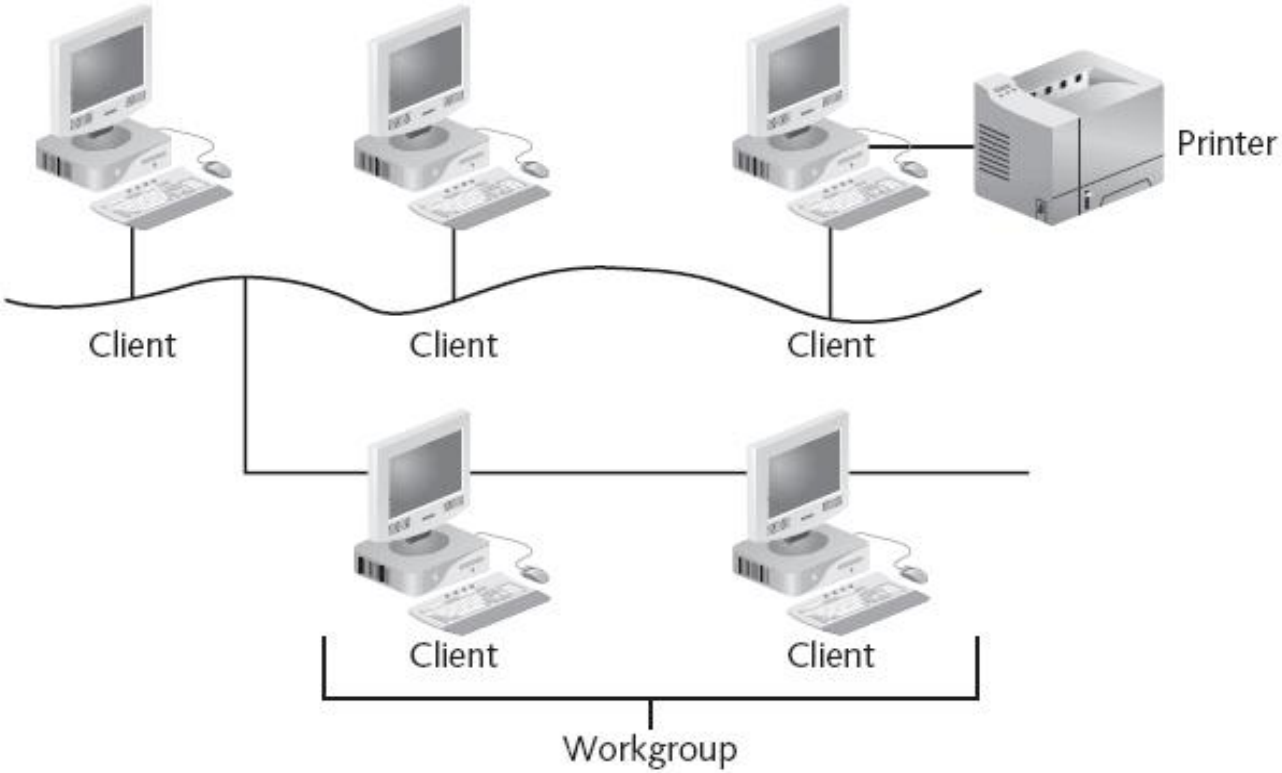
- Client Server Model
  - Client Host Requests for the Service.
  - Example : Browser
  - Server Provides Response.
  - Example : Web Server
  - High End Servers can Process Multiple Requests at a Time.

- Peer to Peer Model
  - No Use of Dedicated Servers.
  - Example : Bit Torrent

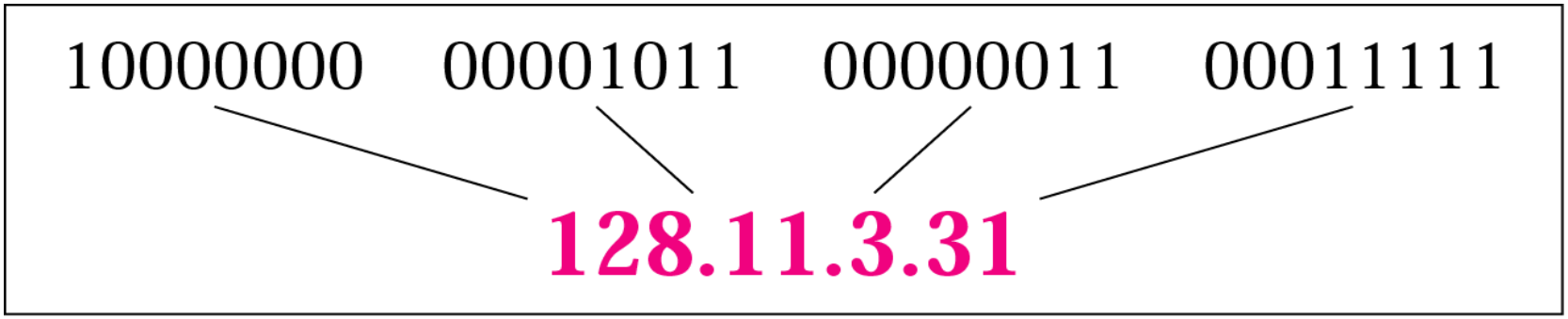
Network Models: Client Server Model



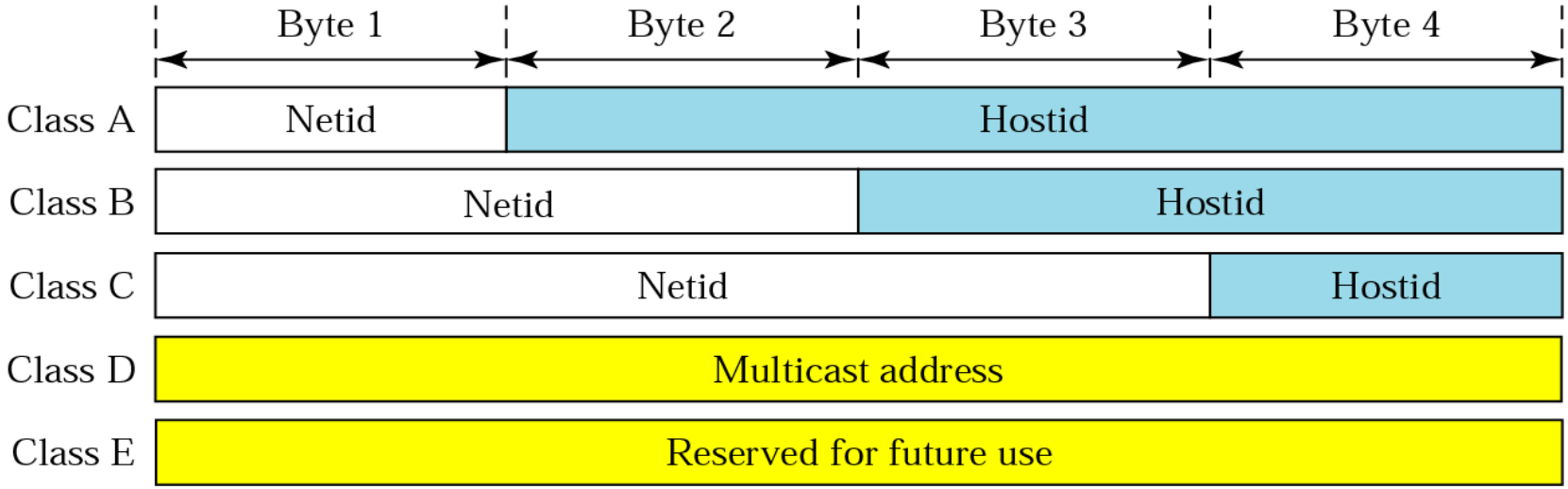
Network Models: Peer to Peer Model



IPv4 Address : Representation in Dotted Decimal Notation



IPv4 Address : Two Levels of Hierarchy



IPv4 Address : Subnet and Subnet Mask

Class	Default Subnet	Subnet Mask
Class A	/8	255.0.0.0
Class B	/16	255.255.0.0
Class C	/24	255.255.255.0

IPv4 Address : Private IP Address Space

Range	Total Hosts
10.0.0.0 - 10.255.255.255	2^{24}
172.16.0.0 - 172.31.255.255	2^{20}
192.168.0.0 - 192.168.255.255	2^{16}

IPV6 : Internet Protocol Version 6

- It is Known as Internetworking Protocol Next Generation (IPng).
- It is suitable for Fast growing Internet.
- It is also suitable for Next Generation Networks (NGN).
- Features
  - ✓ Larger Address Space (128 Bit Address Space).
  - ✓ Supports Resource Allocation via Flow Control Field.
  - ✓ Supports More Security.
  - ✓ Better Header Format (Base Header and Extension Header)

IPV6 : 128 Bit Addressing Scheme

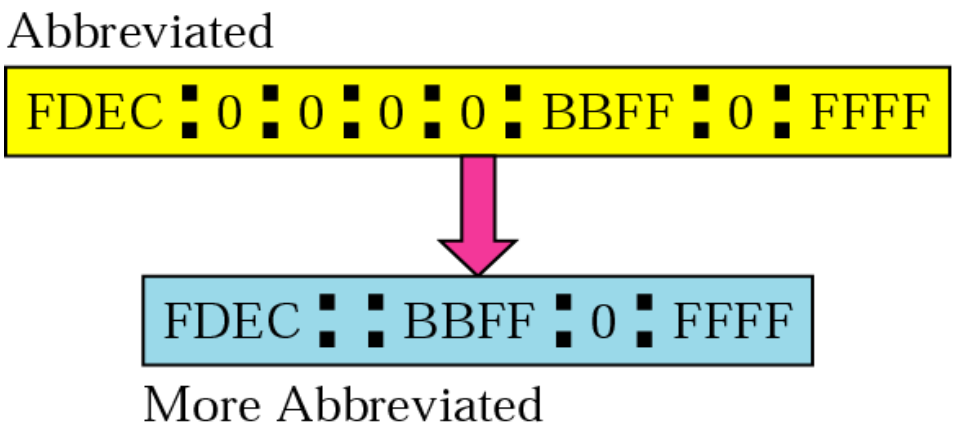
Unabbreviated

FDEC : BA98 : 0074 : 3210 : 000F : BBFF : 0000 : FFFF

FDEC : BA98 : 74 : 3210 : F : BBFF : 0 : FFFF

Abbreviated

IPV6 : Abbreviated Address

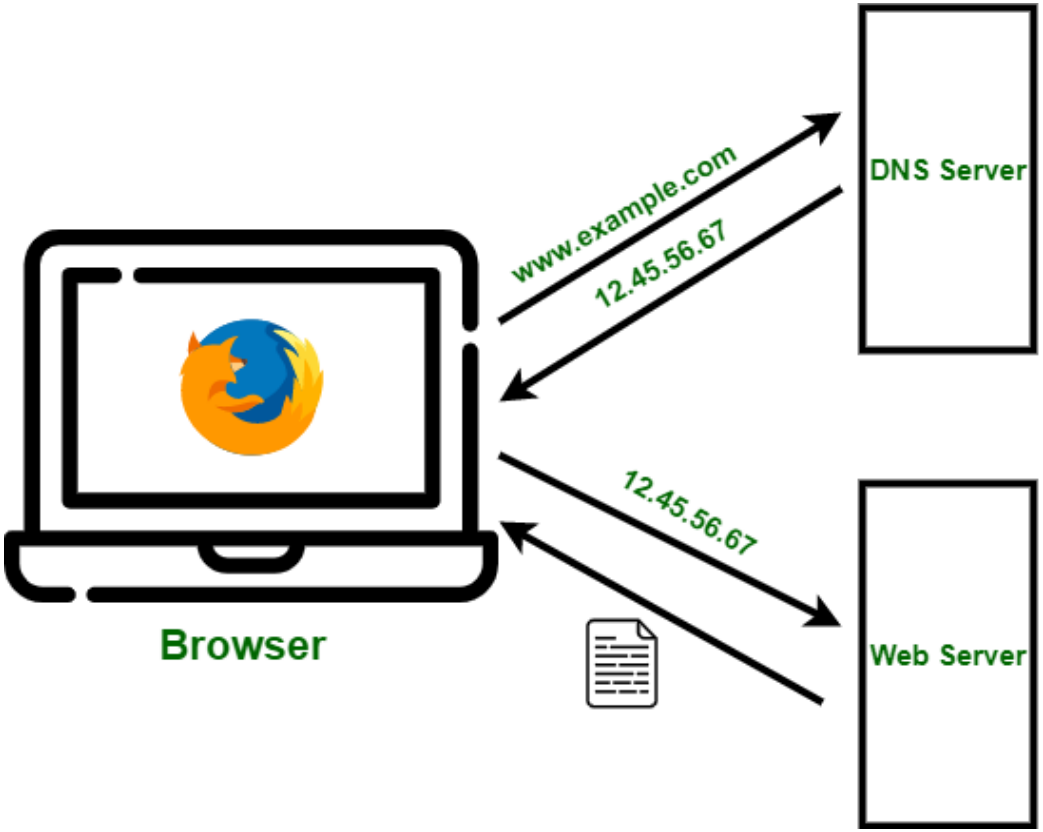


Fundamental of DNS

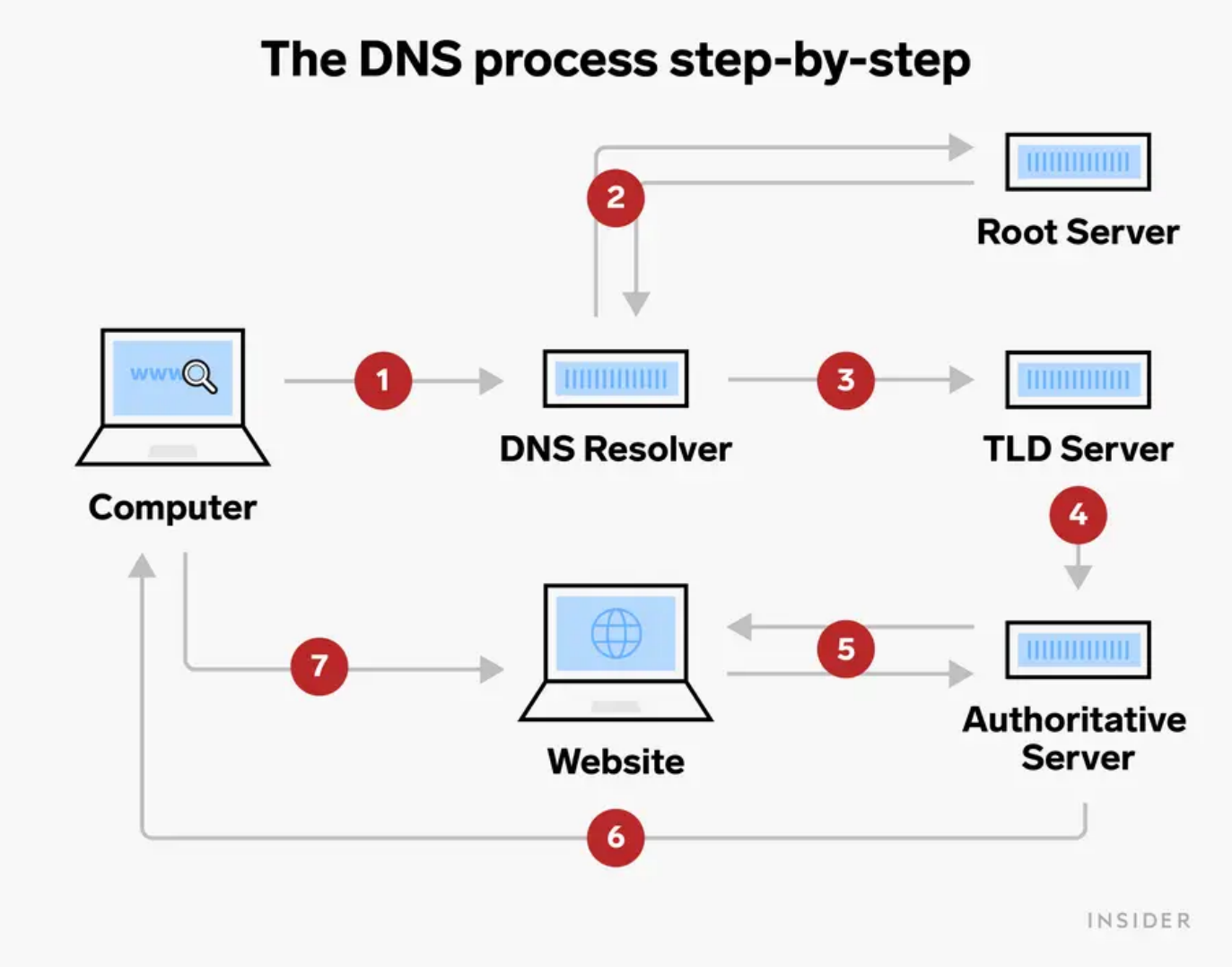
- A DNS (Domain Name System) server is a critical component of the internet infrastructure responsible for translating human-readable domain names into machine-readable IP addresses.

- It functions as a distributed hierarchical database that maps domain names to their corresponding IP addresses, allowing users to access websites and other internet services using easy-to-remember domain names rather than complex numerical IP addresses.

Fundamental of DNS



Fundamental of DNS



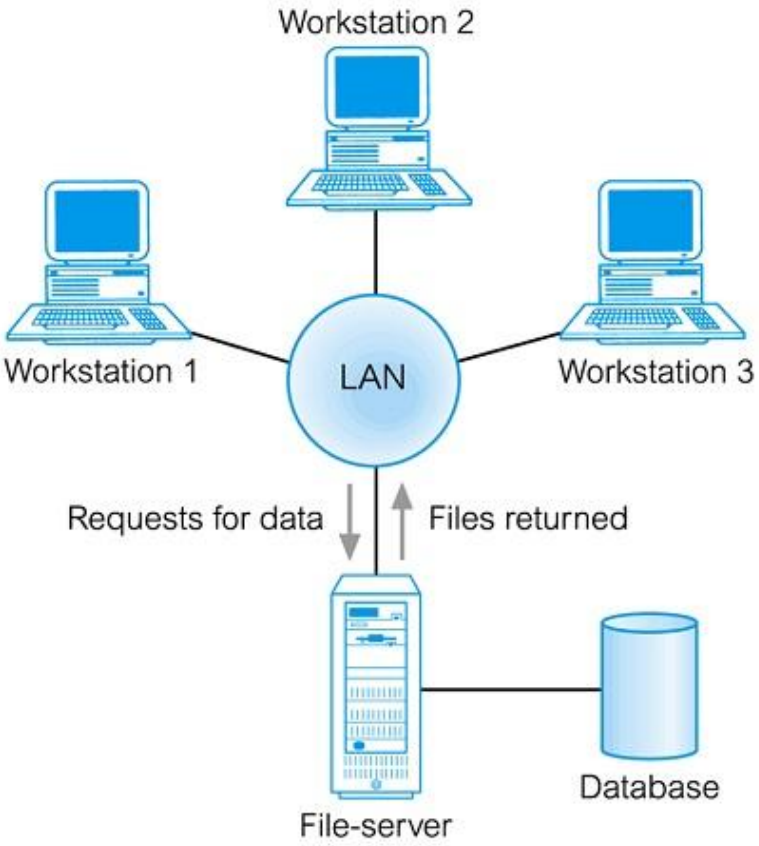
Fundamental of Web Server

- ✓ A **Web Server** is a software application or hardware device that serves web content to clients over the internet or an intranet.
- ✓ It responds to requests from web browsers or other client applications by delivering web pages, files, or other resources stored on the server to the requesting clients.
- ✓ Web servers play a central role in facilitating the exchange of information and enabling access to websites, web applications, and other online resources

Fundamental of File Server

- ✓ A file server is a computer or network device that stores, manages, and provides access to files and data for client devices within a network.
- ✓ Its primary function is to act as a centralized repository for storing files, making them accessible to users or other devices over the network.

Fundamental of File Server



Information : ??

Information is a Virtual Asset which, like other important business assets, has value to an organization and consequently needs to be suitably Protected.

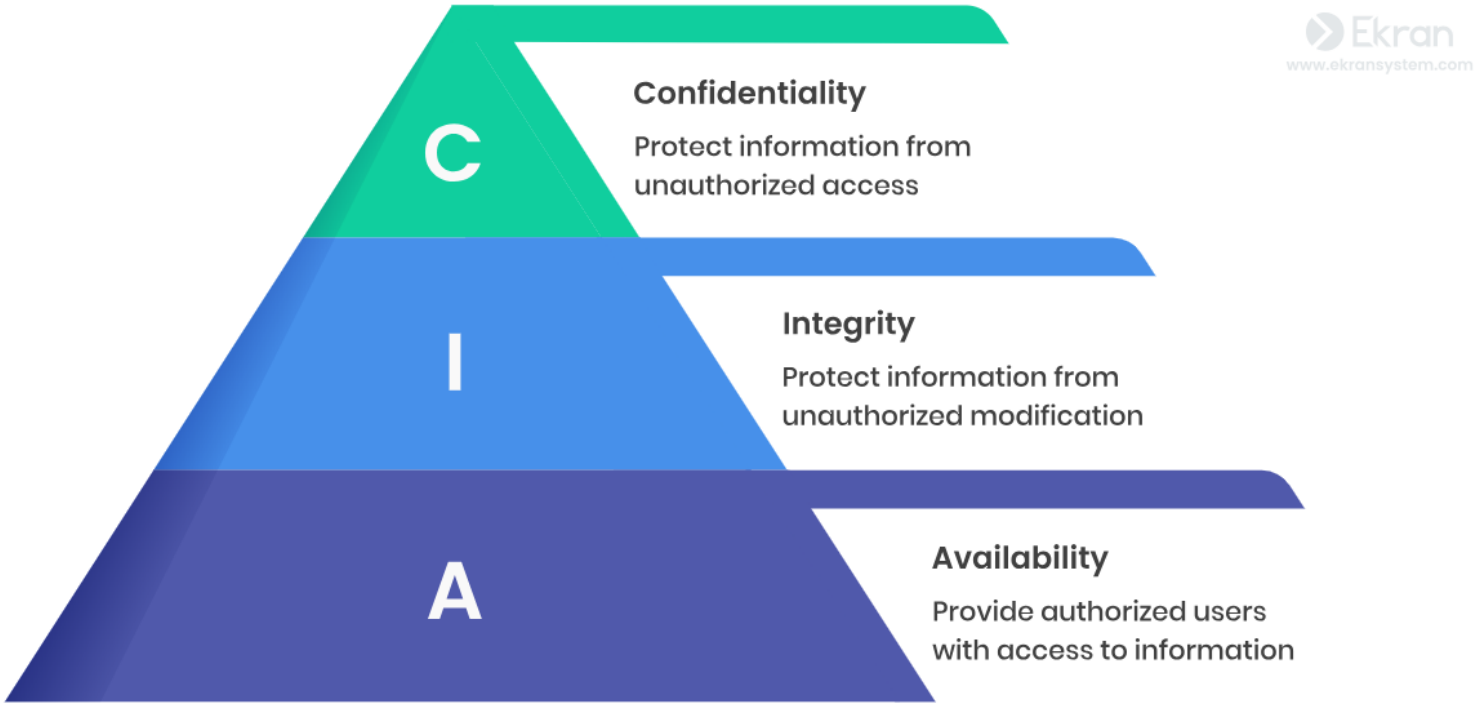
ISO/IEC 27002:2005

Information Security: Key Terms

- Information Security is a process by which Digital Information assets are Protected.

- It is not something you BUY, it is something you DO
  - It's a ***PROCESS*** not a ***PRODUCT***
- It is achieved using a combination of suitable strategies and approaches:
  - Determining the **RISKS** to information and Treating them accordingly (Proactive Risk Management)
  - Protecting **CIA** (**C**onfidentiality, **I**ntegrity and **A**vailability)
  - Avoiding, preventing, detecting and recovering from incidents
  - Securing people, processes *and* technology … not just IT!

Principles of Information Security



Principles of Information Security

Confidentiality

- ✓ Confidentiality ensures that information is accessible only to those authorized to access it.
- ✓ Protecting data confidentiality involves implementing measures to prevent unauthorized access, disclosure, or interception of sensitive information.

Techniques to Ensure Confidentiality

•**Encryption**: Encrypting data in transit and at rest to make it unreadable to unauthorized users.

•**Access Control**: Limiting access to information through mechanisms such as passwords, biometrics, and security tokens.

•**Network Security**: Using firewalls, VPNs, and secure communication protocols to protect data.

Principles of Information Security

Integrity

- ✓ Integrity involves ensuring that information is accurate and reliable and has not been tampered with.
- ✓ This principle guarantees that data is not altered or destroyed in an unauthorized manner.

Techniques to Ensure Integrity

Hashing: Using cryptographic hash functions to verify that data has not been altered.

Digital Signatures: Providing a means for the receiver to verify the authenticity and integrity of a message.

Version Control: Keeping track of changes to data and ensuring that only authorized modifications are made.

Principles of Information Security

Availability

- ✓ Availability ensures that information and resources are accessible to authorized users when needed.
- ✓ This principle involves maintaining the functionality of systems and networks to ensure timely access to information.

Techniques to Ensure Availability

Redundancy: Implementing redundant systems and backups to prevent single points of failure.

Disaster Recovery Plans: Preparing for potential disruptions with comprehensive recovery strategies.

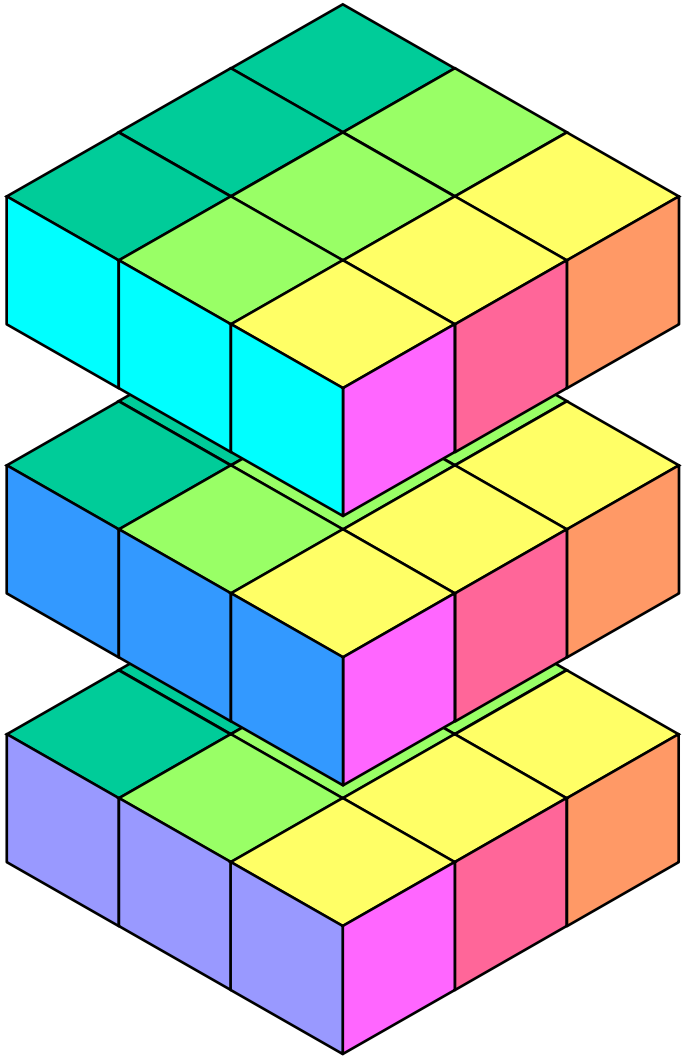
Regular Maintenance: Performing regular updates and patches to keep systems running smoothly.

Information Security Properties

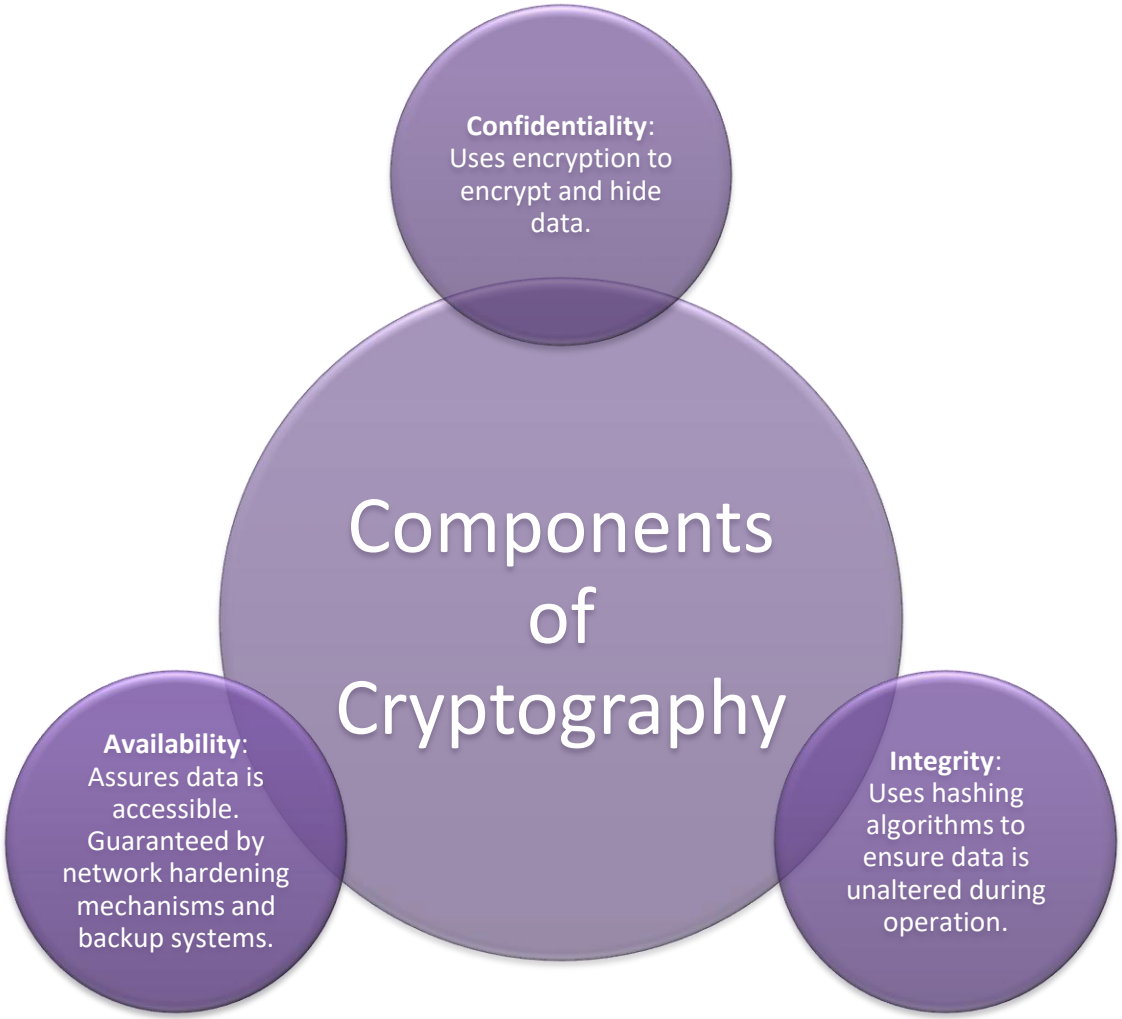
Confidentiality

Integrity

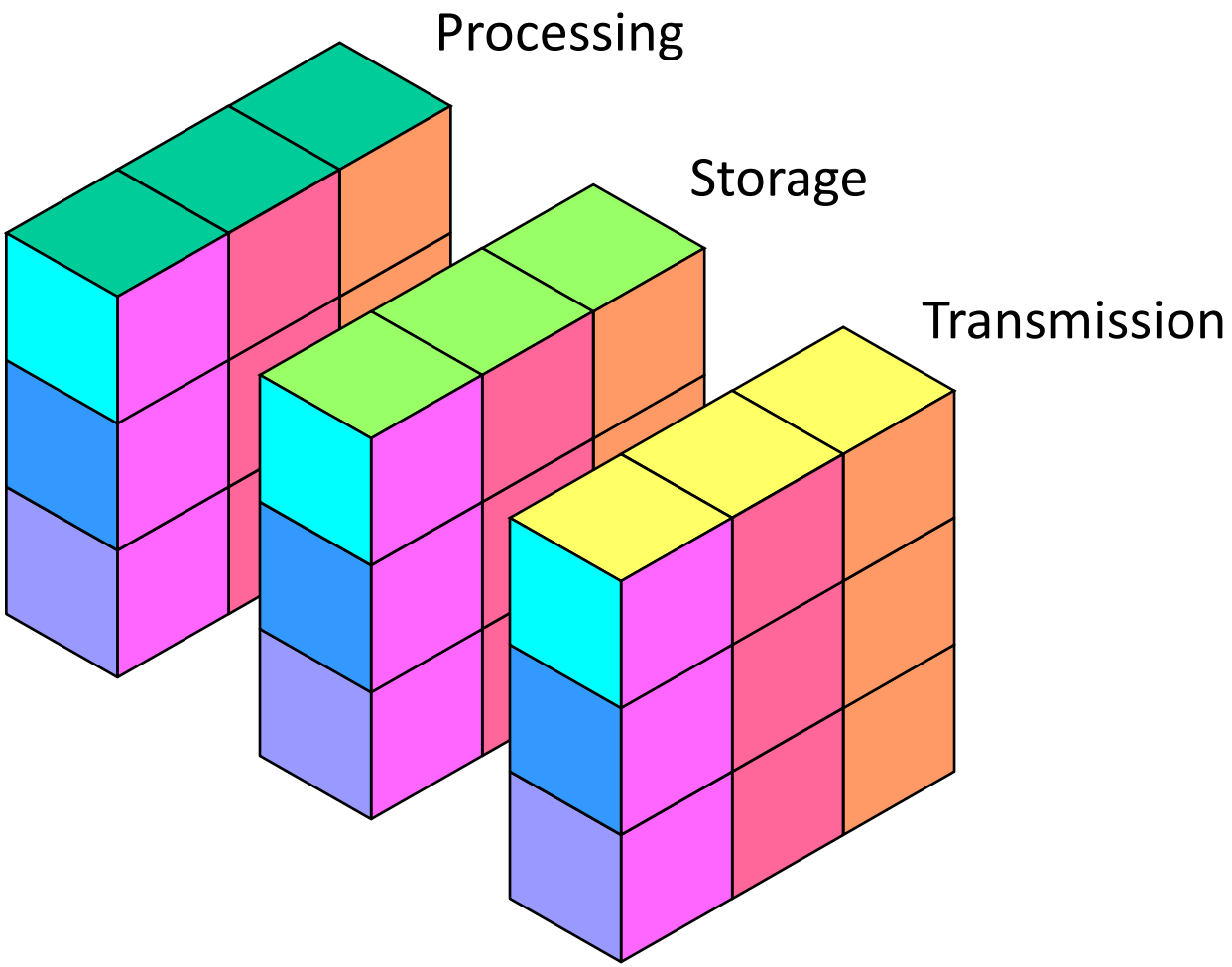
Availability



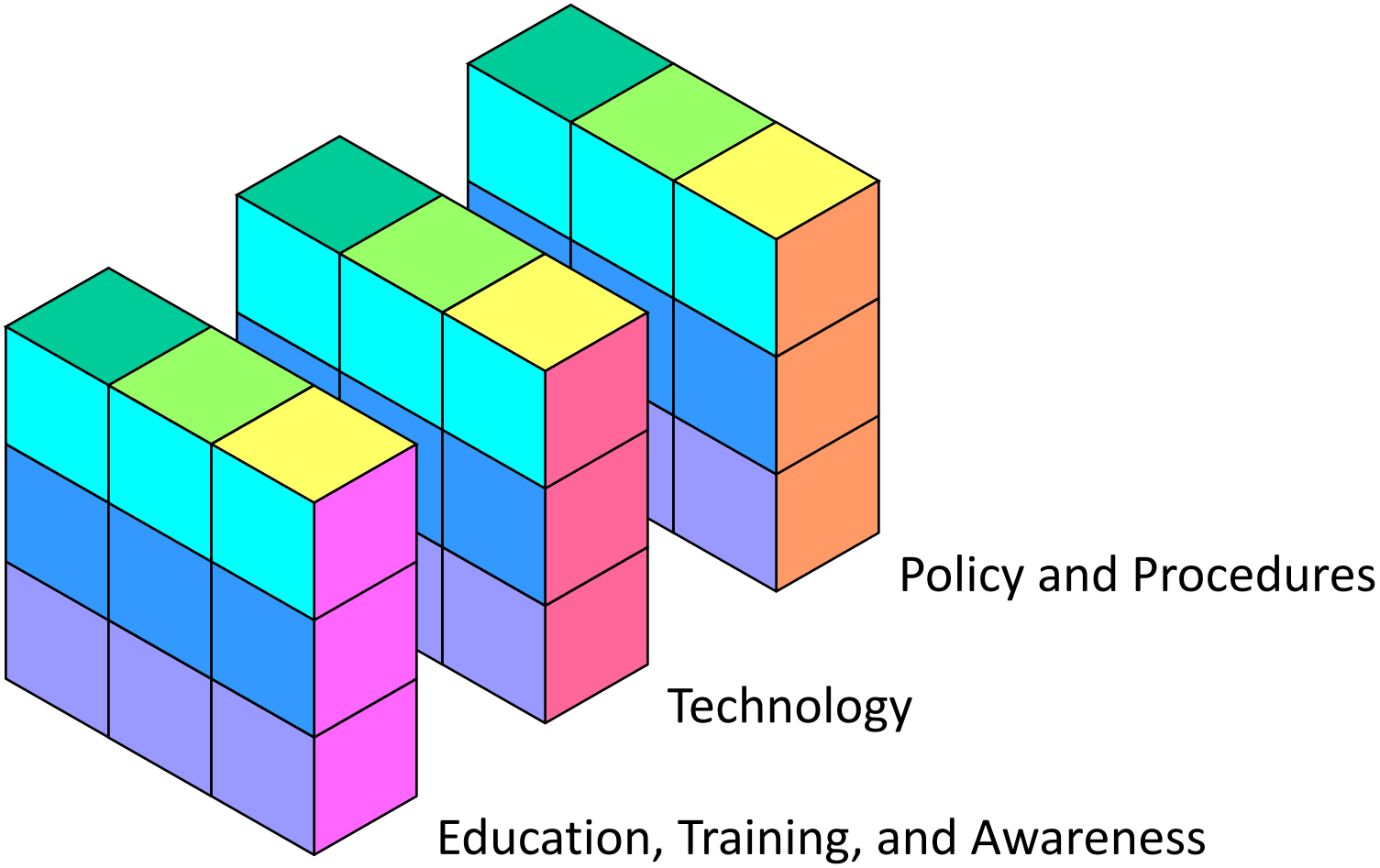
Confidentiality, Integrity, Availability



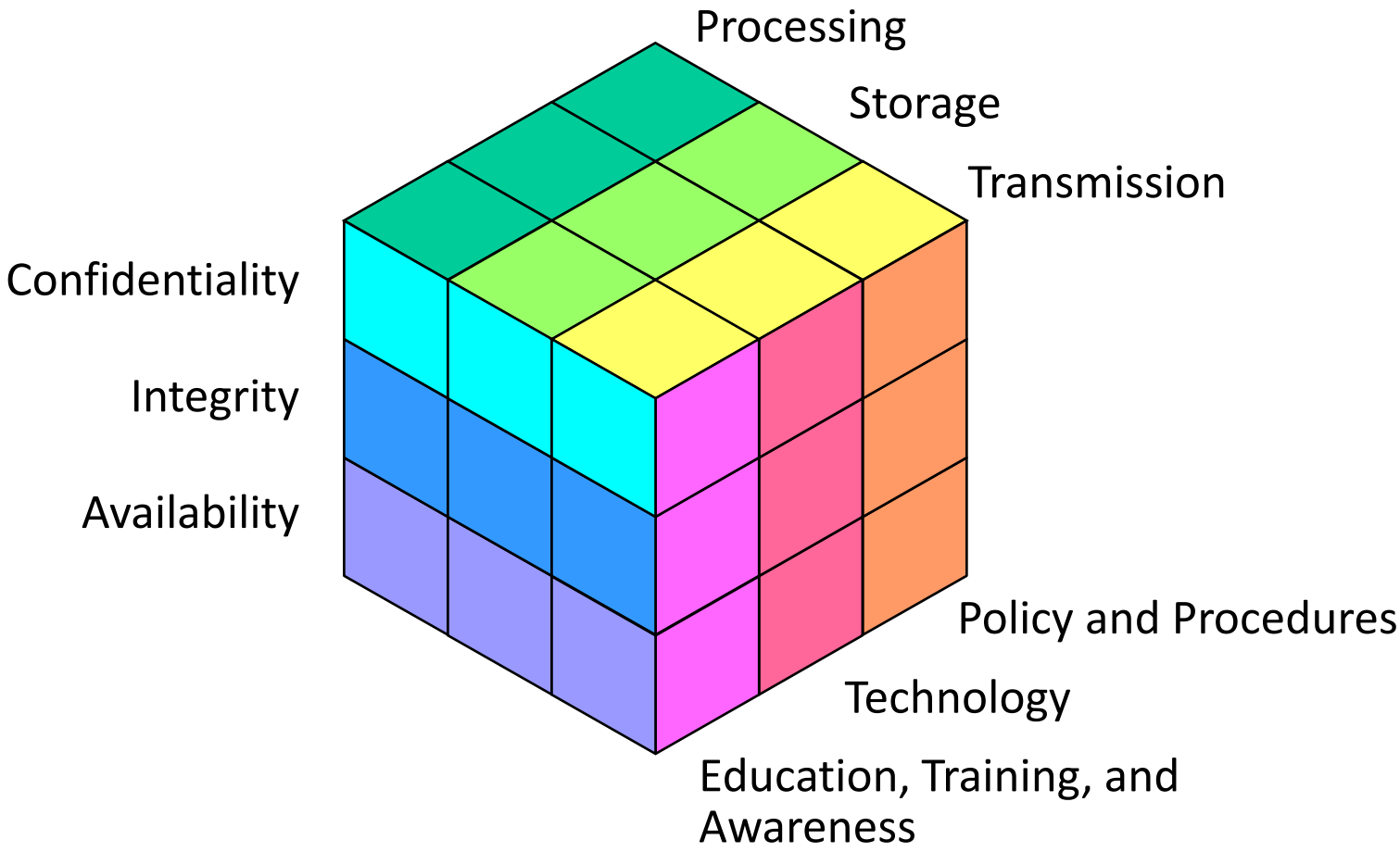
Information States



Security Measures



Information Security Model



© Kumar Pudashine

Information Security Life Cycle

© Kumar Pudashine

Information Security : Defense in Depth Approach

GOVERNANCE & RISK MANAGEMENT

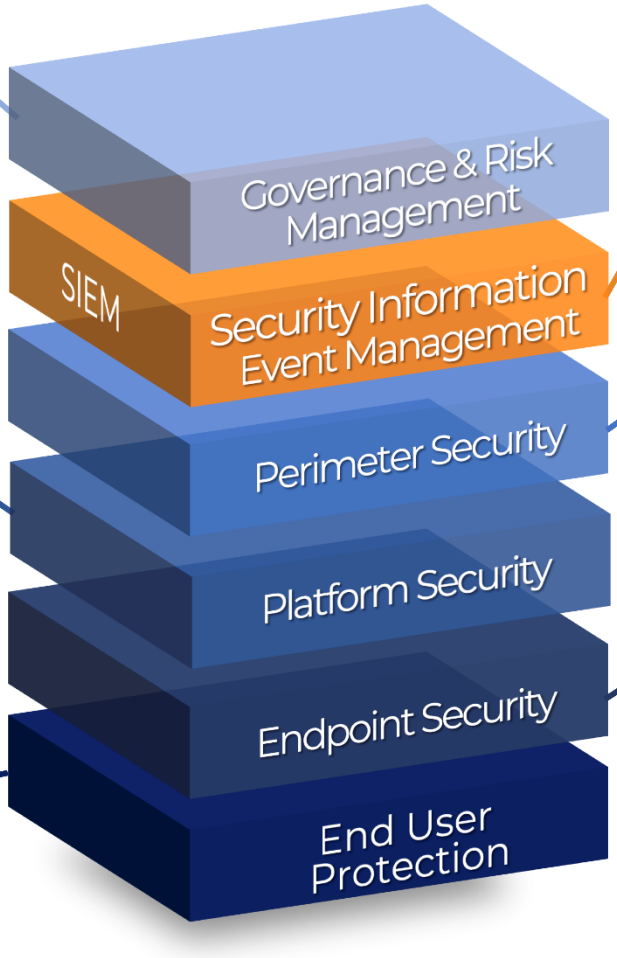
- ISO 27002 Compliant
- Center for Internet Security (CIS) Controls
- 3 Annual Pen Tests
- Privacy Shield Certified
- GDPR / CCPA Compliant
- Enterprise Risk Register
- NIST SP 800-53 Compliant
- SSAE 18 SOC 1 Type 2 Certified
- Standard Information Gathering (SIG)
- Information Security Audit Reports
- Enterprise Incident Response

PLATFORM SECURITY

- Next Generation Firewalls
- Antivirus for Servers
- AES 256 Encryption at Rest
- Segregated Active Directory & VLANS
- Privileged Account Vaulting
- Continuous Vulnerability Scanning & Patch Management
- Secure Data Backups and Disaster Recovery
- Operating Systems Hardening

END USER PROTECTION

- Cybersecurity Awareness Training
- Multifactor Authentication
- Role-Based Access Control
- Simulated Phishing Campaigns



SIEM

- Raw Logs, Endpoint Data & Network Traffic Analytics
- Unified Log Data
- User Behavior Analytics (UBA)
- Suspicious Activity Detection & Alerts

PERIMETER SECURITY

- External Firewalls
- Remote Access
- Spam Filtering
- Threat Intel Feeds
- Remote Authentication Reporting
- Brute Force and DoS Detection
- Data Center Physical Security

ENDPOINT SECURITY

- Automated Microsoft Windows and 3rd Party Application Patch Management
- Antivirus and Endpoint Detection & Response (EDR)
- Remote Monitoring & Management System
- Local Admin Password Solution
- Full Disk Encryption
- Mobile Device Management
- Group Policy Enforcement
- Password Complexity
- Brute Force Prevention

Common Security Threats and Vulnerabilities

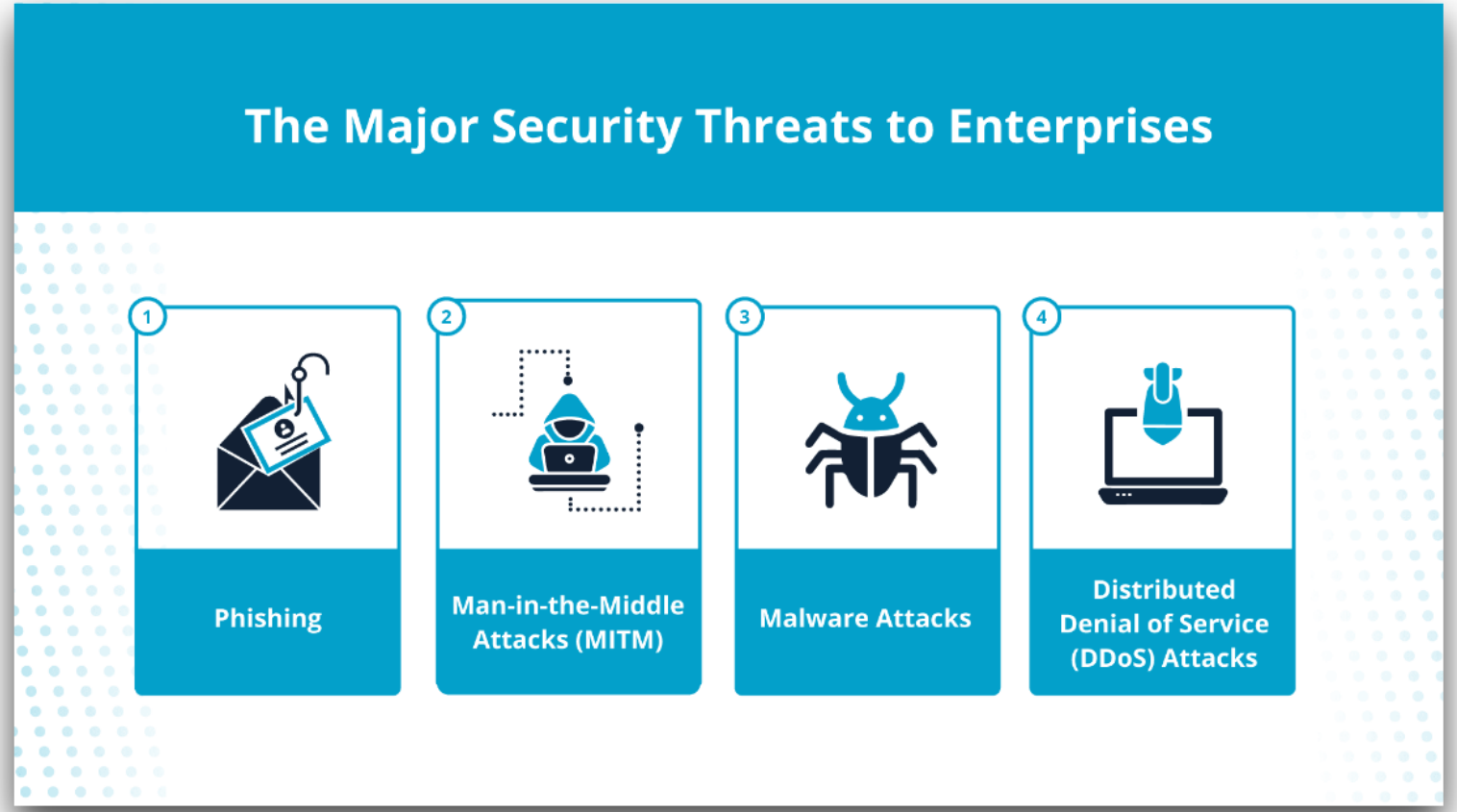
- A **Threat** is any potential event, condition, or activity that could exploit vulnerabilities and cause harm to information systems, data, or network infrastructure.

- Threats can lead to unauthorized access, data breaches, data corruption, system downtime, and other adverse effects that compromise the confidentiality, integrity, and availability of information.

- **Vulnerability** refers to a weakness or flaw in a system, network, application, or process that could be exploited by a threat to compromise the security of the system, leading to unauthorized access, data breaches, or other security incidents.

© Kumar Pudashine

Common Security Threats



© Kumar Pudashine

Common Security Threats

Malware

1. **Viruses**: Malicious code that attaches to clean files and spreads to other files. It can delete files, corrupt systems, or allow unauthorized access.
2. **Worms**: Self-replicating malware that spreads without user action, often exploiting network vulnerabilities.
3. **Trojans**: Malicious code disguised as legitimate software. Once activated, they can give attackers access to the user's system.
4. **Ransomware**: Encrypts user data and demands payment for the decryption key.
5. **Spyware**: Secretly monitors user activities and collects sensitive information.

© Kumar Pudashine

Common Security Threats

Phishing

1. **Email Phishing**: Deceptive emails that appear to be from legitimate sources, prompting users to reveal personal information.
2. **Spear Phishing**: Targeted phishing attacks aimed at specific individuals or organizations.
3. **Smishing and Vishing**: Phishing through SMS (smishing) or voice calls (vishing).

Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks

1. **DoS**: An attack that floods a system with traffic to overwhelm resources and make it unavailable to users.
2. **DDoS**: Similar to DoS but involves multiple compromised systems (botnets) attacking a target simultaneously.

© Kumar Pudashine

Common Security Threats

Man-in-the-Middle Attacks

1. **Eavesdropping**: Intercepting communication between two parties to steal or manipulate data.
2. **Session Hijacking**: Taking control of a user session by intercepting session tokens.

Advanced Persistent Threats (APTs)

1. Long-term targeted attacks where intruders gain unauthorized access and remain undetected for an extended period, typically for espionage or data theft.

Insider Threats

1. Malicious actions taken by employees or former employees, contractors, or business associates who have inside information concerning the organization's security practices, data, and computer systems.

© Kumar Pudashine

Common Vulnerabilities

Software Vulnerabilities

1. **Unpatched Software**: Outdated software with known vulnerabilities that have not been fixed.
2. **Buffer Overflows**: Occurs when a program writes more data to a buffer than it can hold, potentially allowing attackers to execute arbitrary code.
3. **SQL Injection**: Injection of malicious SQL code through input fields to manipulate the database.
4. **Cross-Site Scripting (XSS)**: Injection of malicious scripts into webpages viewed by other users.

© Kumar Pudashine

Common Vulnerabilities

Network Vulnerabilities

1. **Open Ports**: Unnecessary open ports that can be exploited to gain unauthorized access.
2. **Weak Encryption**: Using outdated or weak encryption methods that can be easily broken.
3. **Default Configurations**: Using default settings that are often insecure and well-known to attackers.

Authentication and Authorization Vulnerabilities

1. **Weak Passwords**: Easily guessable or commonly used passwords.
2. **Poor Access Controls**: Inadequate restrictions on user permissions, allowing unauthorized access.

© Kumar Pudashine

Common Vulnerabilities

Physical Vulnerabilities

1. **Insecure Physical Access**: Lack of physical security measures to prevent unauthorized access to systems and data centers.
2. **Device Theft**: Loss or theft of devices containing sensitive information.

Human Factor Vulnerabilities

1. **Social Engineering**: Manipulating individuals into performing actions or revealing confidential information.
2. **Lack of Security Awareness**: Insufficient training and awareness among employees regarding security best practices.

© Kumar Pudashine

Security Best Practices for Servers and Network : Servers

1. Patch Management
2. Secure Configuration
3. Access Control
4. Data Encryption
5. Logging and Monitoring
6. Backup and Data Recovery

© Kumar Pudashine

Security Best Practices for Servers and Network : Networks

1. Network Segmentation
2. Firewall Configuration
3. Intrusion Detection and Prevention
4. Wireless Network Security
5. User Awareness and Training
6. Physical Security

© Kumar Pudashine

Assignment

Discuss in detail about security best practices for Servers and Networks with a suitable example.

© Kumar Pudashine

Thank You